

DARI: 거버넌스 기반 AI 추론을 위한 위임 인가와 검증 가능 실행 증거

Patrick Rho
Patty Co., Ltd.

2026년 8월

초록

AI 코딩 에이전트는 비공개 저장소를 읽고, 외부로 전송할 정보를 선택하며, 모델과 도구를 호출하고, 파일을 수정하여 커밋을 생성할 수 있다. 그러나 커밋이 생성된 뒤에는 기본적인 책임성 질문, 즉 누가 그러한 결과를 초래할 권한을 부여받았는가에 답하기 어렵다. 오늘날의 시스템에서도 API 자격 증명, 게이트웨이 판단, 도구 로그, Git 이력을 통해 답의 일부를 복원할 수 있다. 그러나 인간의 의도에서 모델 호출과 실행 가능한 부수 효과에 이르는 전 과정에 동일한 제한적 권한이 적용되었음을 신뢰성 있게 입증하지는 못한다. 이러한 한계는 독립적으로 생성된 기록을 사후에 연계하는 방식이 아니라 권한을 내재한 교환을 요구한다.

본 논문은 DARI(Delegated Authorization and Receipts for Inference)를 제안한다. 위임 인가(delegated authorization)는 권한 주체가 보유한 권한의 일부를 명시적인 범위와 조건에 따라 다른 참여자에게 부여하는 검증 가능한 관계를 의미한다. 이하에서는 이를 권한 위임이라 한다. DARI의 중립적 커널은 네 객체로 구성된다. Credential은 피어와 검증 자료를 결합하고, Authorization Grant(인가 증서)는 서명된 제한적 권한을 표현하며, Governed Exchange(거버넌스 적용 교환)는 해당 권한 아래 보호 대상 추론과 부수 효과의 상태 전이를 순서화하고, Evidence Receipt(검증 가능 실행 증거)는 그 결과로 생성된 증거에 대한 암호학적 커밋먼트(commitment)를 제공한다. 추론 피어(Inference Peer)는 호출자가 지정한 엔드포인트가 아니라 모델 아티팩트 명세서(Model Artifact Manifest)를 통해 선택된다. 모델은 행위를 제안할 수 있지만 실행 권한을 스스로 생성할 수는 없다.

평가 대상 구현은 결정적 프레이밍, 정규 CBOR, TLS/TCP 및 QUIC 전송 바인딩을 구현한다. transcript 결합 피어 인증, 정규 형식으로 서명된 인가 범위, 위임 범위 축소, 결정적 최종 검증 가능 실행 증거는 명세가 요구하는 속성이며, 이를 완전하게 구현한 프로토콜 소스와 테스트는 아직 필요하다. 브라우저 바인딩과 도메인 간 연합은 확장 프로파일이다. Apple M4 Pro 환경에서 1 KiB 레코드 왕복, 증거 체인 갱신, 객체 다이제스트, Ed25519 서명 및 검증으로 구성된 비교 연산 묶음의 처리 시간은 43.45 μ s였다. 이는 MLPerf Inference의 상호작용형 LLM TTFT 기준 450 ms의 0.0097%로, 네 자릿수 이상의 차이에 해당한다 [10]. 1 MiB 레코드의 인코딩·디코딩 처리량은 10.81 GB/s였다. 이 핵심 연산 측정은 권한 위임, 브라우저 전송, 연합, 네트워크 정책 또는 중단 간 추론을 측정할 결과가 아니다.

1 서론

다음과 같은 사고를 가정한다. 개발자가 에이전트에게 실패한 권한 부여 테스트의 수정을 요청한다. 에이전트는 저장소 파일 여섯 개를 컨텍스트로 선택하고, “Model A”라는 이름의 모델을 호출한 뒤 셸 도구 제안을 받아 마이그레이션을 실행한다. 이어 두 파일을 수정하고 커밋을 생성한다. 수 시간 후 이 마이그레이션이 테넌트 데이터를 노출했다는 사실이 드러난다. 이때 조직은 다음 질문에 답해야 한다.

- 어떤 인간 사용자와 어떤 설치형 에이전트가 작업을 시작했는가?
- 해당 에이전트는 그 모델에 여섯 개 파일을 공개할 권한이 있었는가?
- 어느 불변 정책 버전이 마이그레이션 명령을 허용했는가?
- 모델은 명령을 제안했을 뿐인가, 아니면 권한을 부여받은 런타임이 이를 실행했는가?

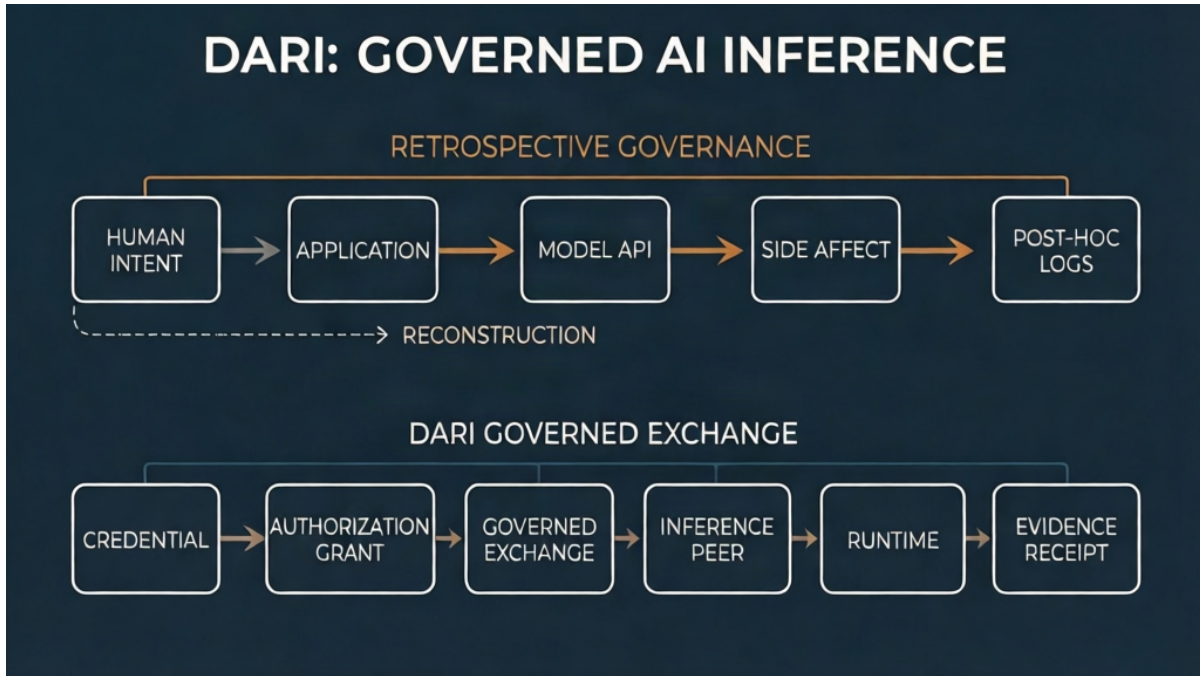


그림 1: 사후 거버넌스와 DARI의 거버넌스 적용 교환 비교. DARI는 제한적 권한, 모델 신원, 인과 증거를 실제 처리 경로의 조건으로 표현한다. 본 그림은 개념도이며 측정 데이터나 구현 범위에 관한 주장을 포함하지 않는다.

- 정확히 어떤 모델 아티팩트와 추론 피어가 제안을 생성했는가?
- 모델 출력 중 어느 부분이 인간의 수정 이후에도 최종 커밋에 남았는가?

각 구성 요소가 유지하는 로그는 서로 다른 경계를 기술한다. API 인증은 호출자를 식별하고, 게이트웨이는 라우팅이나 정책 판단을 기록하며, 샌드박스는 명령 실행을, Git은 최종 산출물을 기록한다. 하나의 인과관계와 권한 부여 과정을 구성하려면 서로 다른 식별자, 시간 기준, 보존 정책 및 신뢰 가정에 따라 생성된 기록을 상호 연계해야 한다. 기록 사이의 단절이나 모호성은 시스템 변경이 끝난 뒤에야 드러날 수 있다.

이러한 분절은 **프로토콜 모델의 공백**에서 비롯된다. 기존 AI 인터페이스는 프롬프트, 토큰, 도구 호출, 작업, 산출물을 전달하지만, 해당 객체가 부수 효과를 일으킬 때 적용되는 제한적 권한을 표현하지 않는다. 그 결과 거버넌스는 프로토콜 상태 전이의 조건이 아니라 외부 미들웨어로 남는다. DARI는 신원, 권한, 정책, 인과 증거를 추론 및 행위 수명주기에 포함한다.

DARI는 권한을 내재한 교환으로 이 공백을 다룬다. 보호 대상 교환은 관련 Credential, 인가 증서, 인가 결정, 모델 아티팩트 명세서가 모두 부합할 때에만 다음 상태로 진행한다. TLS 연결의 성립이나 모델이 생성한 도구 호출만으로는 충분하지 않다. 그림 1은 이 프로토콜 구조를 요약한다.

1.1 연구 기여

본 논문은 에이전트형 AI 프로토콜이 메시지와 작업을 해당 작업의 권한 정보 및 인과관계 증거와 함께 전달해야 한다는 주장을 검토하며, 다음 네 가지를 기여한다.

1. **중립적 프로토콜 커널.** 보호 대상 추론과 부수 효과에 필요한 최소 권한·증거 객체로 Credential, 인가 증서, 거버넌스 적용 교환, 검증 가능 실행 증거를 정의한다.
2. **권한 위임 체인.** 부모 증서에 결합되어 서명되고 범위가 단조롭게 축소되는 인가 증서를 정의하며, 모델 아티팩트 명세서와 선택된 추론 피어를 분리한다.
3. **증거 상태 경계.** 구현된 프레임·전송 기반과 아직 구현이 필요한 인증, 인가, 위임, 검증 가능 실행 증거

속성을 구분한다.

4. **개방형 통합 경계.** 독립적인 제품이 호환되는 거버넌스 적용 교환을 도입할 수 있도록 중립적 커널과 응용, 브라우저, 연합, 벤더별 프로파일을 분리한다.

본 연구의 기여는 구성적이다. 보안 전송, 역량 기반 권한, 프로비넌스 DAG, 서명된 검증 가능 실행 증거, 도구 프로토콜은 이미 존재한다. DARI는 그 권한 의미론을 응용-거버넌스-추론/런타임 경계의 하나의 실시간 상태 기계에 통합한다. 명세는 부수 효과 발생 전 거버넌스 적용과 프로토콜 출력으로서의 증거 생성을 요구하며, 주장 행렬은 이 구성의 구현 범위를 명시한다.

2 에이전트형 AI 통신의 거버넌스 공백

앞의 사고 사례는 에이전트 시스템에서 반복되는 세 가지 불일치를 드러낸다.

인증은 권한 이력이 아니다. 유효한 API 자격 증명은 요청을 시작한 주체를 식별할 수 있으나, 장시간 이어지는 작업에서 어떤 저장소와 모델을 사용할 수 있는지, 어떤 목적으로 어느 도구를 실행하고 외부 상태를 변경할 수 있는지까지 보여주지는 못한다. 에이전트 작업은 개별 요청보다 오래 지속되며, 서로 다른 권한 모델을 사용하는 여러 구성 요소를 거친다.

모델 출력은 실행 권한이 아니다. 도구 호출 형식은 제안된 행위를 기계 판독 가능하게 만들 뿐 정당하게 만들지는 않는다. 모델이 특정 구문을 출력했다는 이유로 실행이 가능하다면, 신뢰할 수 없는 저장소 텍스트는 프롬프트 인젝션을 통해 권한을 획득하려 할 수 있다. 따라서 집행 경계는 제안, 승인, 실행을 서로 다른 주체가 담당하는 별개의 사건으로 구분해야 한다.

로그는 사건을 기록하지만 단일 인과 경로를 반드시 입증하지는 않는다. 상관 식별자는 유용하지만 상관관계가 프로토콜로 강제된 체인과 동일하지는 않다. “누가 이 커밋을 승인했는가”에 대한 지속 가능한 답은 실행 전에 존재했던 권한 및 정책에 행위를 결합하고, 이후 인간과 자동화 작업을 거치며 결과가 어떻게 변했는지 보존해야 한다.

따라서 보안 전송과 응용별 거버넌스 사이에는 신원, 제한된 권한, 변경 불가능한 정책, 집행 판정, 감사 증거를 하나의 일관된 프로토콜 상태로 관리하는 교환 계층이 필요하다.

3 인접 시스템과 신규성의 경계

모델 API와 게이트웨이. HTTPS/JSON 및 스트리밍 모델 API는 효과적인 요청/응답 인터페이스이며, 게이트웨이는 인증, 할당량, 정책, 로깅을 추가할 수 있다. DARI의 주된 차이는 상태의 단위이다. 인가와 증거를 독립적인 미들웨어 사건에서 사후 복원하지 않고 거버넌스 적용 교환에 결합한다.

MCP와 A2A. Model Context Protocol(MCP)은 AI 응용과 컨텍스트/도구 제공자 간 상호작용을 표준화한다 [11]. Agent2Agent(A2A)는 에이전트 탐색, 작업, 메시지, 아티팩트를 표준화한다 [1]. MCP는 거버넌스가 적용되는 도구 브로커 뒤에서, A2A는 에이전트 간 경계에서 동작할 수 있다. DARI는 AI 응용, 인라인 거버넌스, 통제된 추론/런타임 인프라, 증거 검증 사이의 별도 경계를 다룬다.

런타임 거버넌스와 에이전트 보안. MI9은 에이전트 시스템의 통합 런타임 거버넌스를 연구하고 [19], AgentDojo는 프롬프트 인젝션 공격 및 방어 환경을 제공하며 [6], 인자 수준 프로비넌스 연구는 포괄적 인가와 도구 인자 사이의 불일치를 지적한다 [7]. DARI는 이에 상보적이며, 신원, 인가, 도구 권한, 증거를 집행하고 반출할 수 있는 프로토콜 객체와 상태 전이를 정의한다.

공급망 프로비던스. in-toto는 공급망 각 단계의 서명 메타데이터를 기록하고 [8, 18], SLSA는 빌드 및 소스 프로비던스의 기대 수준을 정의한다 [15]. SCITT는 디지털 산출물에 관한 서명된 진술을 등록하고 영수증을 발급하는 투명성 서비스를 정의한다 [4]. DARI는 빌드 산출물이 존재하기 전의 상호작용 단계에서 컨텍스트 공개, 모델 추론, 부수 효과의 허용 여부를 통제한다. DARI 검증 가능 실행 증거는 이후 in-toto/SLSA 증명의 입력이나 SCITT 진술로 사용할 수 있지만, 산출물 투명성만으로 실시간 교환의 권한을 대신할 수는 없다.

신원 및 암호학적 구성 요소. SPIFFE는 워크로드 신원 규약을 제공한다 [16]. DARI는 TLS 1.3 [13], QUIC [9], 결정적 CBOR [5], COSE [14], HPKE [2], TLS 채널 바인딩 [12], COSE 영수증 [17]을 재사용한다. 이 표준들은 전송 및 객체 보안의 기반을 제공하지만 본 연구가 제안하는 응용 수준 권한 모델을 정의하지는 않는다. DARI의 단조적 권한 위임은 Macaroons가 예시하는 역량 축소 원칙을 따른다 [3].

각 인접 기술의 역할은 신규성의 경계를 구분한다. MCP는 도구를 기술하고, A2A는 에이전트 간 작업을 표현하며, SPIFFE는 워크로드를 식별하고, 게이트웨이는 정책을 집행하며, in-toto는 공급망 단계를 증명한다. DARI는 제안된 계산이 인가된 지속적 부수 효과로 전환되는 지점에서 이 요소들을 하나의 거버넌스 상태 기계로 결합한다.

4 요구사항과 위협 모델

4.1 설계 요구사항

사고 사례에서 제기된 질문은 여섯 가지 프로토콜 요구사항으로 정리할 수 있다. (R1) 모든 보호 작업을 등록 피어와 실제 사용자 신원에 연결한다. (R2) 유효기간과 목적이 제한된 권한으로 허용 범위를 통제한다. (R3) 모든 집행 판정을 변경 불가능한 정책 개정본에 연결한다. (R4) 호출자가 임의로 제공한 이름이 아니라 검증 가능한 방식으로 모델 아티팩트와 실행 엔드포인트를 식별한다. (R5) 모델의 작업 제안과 런타임의 승인·실행을 분리한다. (R6) 일반 응용 로그와 독립적으로 보존 가능한 인과관계 증거를 생성한다.

시스템은 관리 권한 주체가 일시적으로 가용하지 않은 상황에서도 동작해야 한다. 따라서 거버넌스 릴레이는 서명 또는 인증된 스냅샷, 폐기 상태, 인가 증서, 모델 아티팩트 명세서를 사용한다. 오래된 상태를 사용할 수 있는 범위는 암묵적 캐시 동작이 아니라 명시적 만료 및 배포 정책으로 제한한다.

4.2 공격자와 비목표

네트워크 공격자, 미등록 클라이언트, 탈취·재생된 자격 증명, 침해된 응용, 프롬프트 인젝션 콘텐츠, 악성 도구 출력, 모델명 위조, 테넌트 간 오조작, 증거 변조를 고려한다. 거버넌스 릴레이 또는 관리자 역시 악의적이거나 침해될 수 있다. 프로토콜은 권한과 증거의 경계를 명시하는 것을 목표로 하지만, 평문을 처리하는 신뢰 릴레이의 열람을 막거나 모델의 올바른 행동을 증명하거나 완전히 침해된 엔드포인트의 프로토콜 외부 행위를 막지는 못한다. 하드웨어 증명과 형식 검증은 선택 가능한 보증 프로파일이며 핵심 프로토콜의 필수 가정은 아니다.

5 거버넌스 적용 교환

거버넌스 적용 교환은 DARI에서 책임 추적이 가능한 AI 작업의 단위이다. 범위는 개별 API 요청보다 넓지만 전체 응용 세션보다는 좁다. 응용이 보호 대상 목적을 선언할 때 시작하며, 결과 증거에 대한 커밋먼트를 담은 검증 가능 실행 증거가 생성되면 종료된다. 이 범위 안에서 추론, 컨텍스트 공개, 모델 선택, 도구 사용, 승인, 출력은 권한을 인식하는 하나의 상태 기계의 전이로 처리된다.

이를 데이터베이스 일관성 대신 거버넌스를 완료 조건으로 삼는 트랜잭션으로 이해할 수 있다. TLS는 바이트가 보호된 채널을 통해 전달되었는지를 확인한다. 거버넌스 적용 교환은 이에 더해 요청 주제, 작업 목적, 적용 정책, 사용할 모델, 제안된 부수 효과가 서로 부합하는지 확인한다. 필수 검증 조건을 충족하지 못하면 보호 대상 전이를 차단하며, 사후 로그 기록으로 이를 대신하지 않는다.

표 1: 중립적 DARI 권한 및 신원 객체. 응용에 노출되는 객체와 배포 신원을 의도적으로 분리한다.

객체	권한 주체	목적	핵심 구분
Credential	등록 권한 주체	키, 피어 프로파일, 도메인, 유효기간 결합	사용자뿐 아니라 프로토콜 피어 식별
인가 증서	인가 권한 주체	작업·모델·도구·컨텍스트 범위의 제한적 부여	유효기간과 대상이 명시된 서명 범위
인가 결정	거버넌스 권한 주체	상태 전이의 판단과 의무 기록	평가 결과이며 그 자체가 권한은 아님
모델 아티팩트 명세서	모델 권한 주체	승인된 아티팩트와 서빙 구성 식별	사람이 읽는 모델명보다 강한 식별
추론 피어	서빙 권한 주체	Credential과 승인 명세서 제시	호출자가 선택하는 인프라가 아닌 배포 역할
거버넌스 적용 교환	거버넌스 권한 주체	하나의 증서 체인 아래 보호 대상 전이 순서화	실시간 권한 및 증거의 단위
검증 가능 실행 증거	증거 서명자	교환 결과와 최종 증거 루트에 대한 커밋먼트 제공	검증 가능한 출력이며 결정적 구현이 필요

5.1 아키텍처와 피어

관리 권한 주체는 신원을 등록하고 인가·모델 상태를 발급하며, 폐기 상태를 관리하고 증거를 색인한다. 이 주체는 권위 있는 기준을 제공하지만 모든 토큰 처리 경로에 동기식으로 참여하지는 않는다. 거버넌스 릴레이는 캐시된 서명 상태를 검증하고, 인라인 인가 결정을 수행하며, 승인된 추론을 라우팅하고, 증거를 추가한다. 추론 피어는 승인된 모델 아티팩트 명세서를 제시하고 DARI의 의미론적 요청을 로컬 엔진 인터페이스로 변환한다. 원시 모델 엔드포인트는 응용의 라우팅 권한이 될 수 없다. 부수 효과 실행기는 독립적인 인가 전이가 완료된 후에만 도구를 실행하고, 증거 검증기는 최종 검증 가능 실행 증거를 검사한다.

5.2 프로토콜 집행과 사후 로깅

로그 스키마는 허용 판정을 기술할 수 있지만, 정보 공개, 모델 배정, 도구 실행에 앞서 그 판정이 이루어지도록 강제할 수는 없다. DARI는 Credential 결합, 인가 증서 제시, 인가 결정, 요청 전달, 도구 인가, 교환 종료를 순서가 정해진 프로토콜 상태 전이로 표현한다. 피어는 보호 대상 작업을 진행하기 전에 이러한 전이를 완료해야 하므로, 프로토콜 집행과 사후 미들웨어 기록이 구분된다.

교환 x 에서 프로토콜 시간 t 에 보호 대상 행위 a 가 시도된다고 하자. DARI는 다음 조건이 성립할 때에만 해당 상태 전이를 허용한다.

$$\text{advance}(x, a, t) = C_x \wedge G_x(a, t) \wedge D_x(a) \wedge R_x(a), \quad (1)$$

여기서 C_x 는 유효한 Credential 결합을 나타내고, $G_x(a, t)$ 는 대상과 범위가 a 를 포함하며 만료되지 않은 인가 증서이다. $D_x(a)$ 는 결합된 정책 상태에 따라 허용된 인가 결정이다. $R_x(a)$ 는 행위별 추가 권한 조건을 묶어 표현한다. 추론에는 승인된 모델 아티팩트 명세서와 추론 피어가 필요하고, 부수 효과에는 독립적인 도구 인가가 필요하다. 식 1는 프로토콜의 수락 조건일 뿐 형식적 보안 증명은 아니다. 어느 논리곱 항이라도 충족되지 않으면 해당 상태 전이를 차단한다. 이 검증 경로와 부정 테스트는 구현된 프레임링 계층에서 추론할 수 없으며 추가 구현이 필요하다.

5.3 전송과 표현

독립 스트림을 지원하는 QUIC은 head-of-line 결합을 줄이므로 선호되는 바인딩이고, TLS 1.3 over TCP는 대체 경로이다. 두 전송 방식은 동일한 응용 계층 의미와 ALPN 식별자를 사용한다. 레코드는 고정 prelude, 정규 헤더,

payload, 논리 lane 식별자, lane sequence로 구성된다. 결정적 CBOR은 재현 가능한 객체 인코딩을 제공하며, Credential, 인가 증서, 모델 아티팩트 명세서, 검증 가능 실행 증거처럼 객체 수준 검증이 필요한 데이터는 COSE 서명으로 보호한다.

응용 인증은 Credential, nonce, 협상 프로파일, 채널 문맥을 결합하여 한 연결에서 캡처한 Credential 증명을 다른 연결에서 재생하지 못하게 한다. DARI 명세는 이 transcript 결합 검증 프로파일을 규정하지만, 완전한 피어 인증 구현과 부정 테스트는 아직 필요하다. 본 논문의 구현 증거는 TLS/TCP 및 QUIC 바인딩을 입증할 뿐 더 강한 인증 주장을 입증하지 않는다.

6 인가 상태 전이

6.1 Credential과 인가 증서

사용자 신원, 응용 신원, 워크로드/세션 신원은 각각 누가 작업을 요청했는지, 어느 소프트웨어 설치본이 요청을 전달했는지, 어떤 범위의 활동이 진행 중인지에 답하므로 분리한다. 등록은 피어에 Credential을 부여할 뿐 추론이나 도구 권한을 부여하지 않는다. 인가 증서는 발급자, 주체, 대상, 확인 키, 범위, 유효기간, 선택적인 부모 증서 해시를 결합한다. 허용 모델, 컨텍스트 경로, 도구 클래스, 토큰 예산, 승인 요건 등 일부 행위만 제한된 기간 동안 부여한다. 전송 연결이 정상이어도 폐기 또는 만료된 증서로 새로운 보호 대상 행위를 수행할 수 없다.

위임 단계 i 에서 DARI가 요구하는 서명된 자식 증서는 다음과 같다.

$$G_i = \text{Sign}_{K_i}(\text{iss}, \text{sub}, \text{aud}, \text{cnf}, \text{scope}_i, t_{\text{nb}}, t_{\text{exp}}, H(G_{i-1})), \quad \text{scope}_i \subseteq \text{scope}_{i-1}. \quad (2)$$

부모 해시는 자식 증서가 권한 체인에서 분리되는 것을 방지하고, 범위의 단조적 축소는 위임을 통한 권한 증폭을 방지한다. 서명 범위의 정규 형식 검증, 부모 체인 검증, 범위를 축소하지 않는 증서에 대한 적합성 테스트는 추가 구현이 필요하다.

6.2 인가 결정과 정책 상태

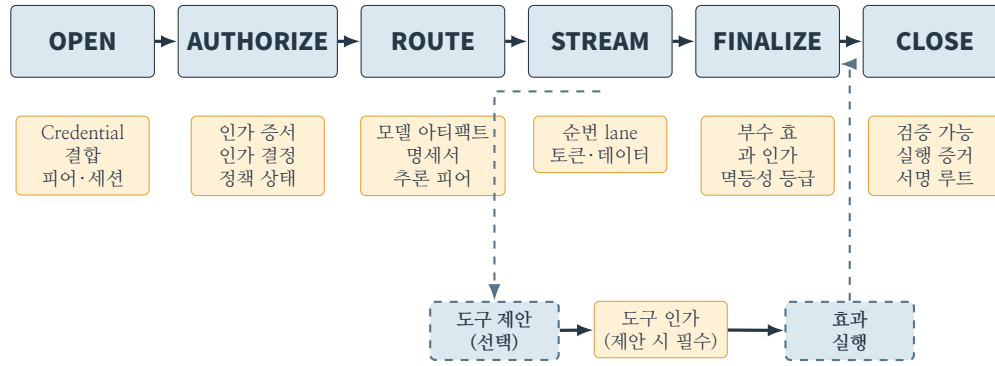
인가 결정은 인가 증서, 행위, 의무, 다이제스트로 식별되는 정책 상태를 결합하여 특정 상태 전이에서 “허용”이 의미한 바를 고정한다. 감사 시점의 최신 정책을 가리키는 포인터가 아니다. 세션 도중 정책이 변경되면 진행 중인 작업은 명시된 규칙에 따라 계속, 재바인딩, 일시정지, 종료 중 하나로 처리하며, 과거 판정의 의미가 암묵적으로 바뀌지 않는다. 보호 대상 콘텐츠가 추론 피어나 부수 효과 실행기에 전달되기 전에 거버넌스 릴레이는 허용, 거부, 변환, 격리, 추가 승인 요구 중 하나와 같은 구조화된 결정을 생성한다.

6.3 교환 수명주기

일반적인 교환은 OPEN, AUTHORIZE, ROUTE, STREAM, FINALIZE, CLOSE 순으로 진행하며, 선택적인 도구 제안 분기를 포함할 수 있다. 이 명칭들은 설명용 레이블이 아니라 각 시점에 허용되는 메시지 종류를 제한하는 프로토콜 상태이다. 거버넌스 릴레이는 요청을 전달하기 전에 Credential, 인가 증서, 인가 결정, 모델 아티팩트 명세서, 추론 피어, 용량 상태를 검증한다. 토큰과 데이터 레코드는 순번이 부여된 lane을 통해 다중화된다. 부수 효과를 일으키는 행위에는 멍등성 등급을 지정하여 연결 복구나 재개 과정에서 완료된 작업이 중복 실행되지 않도록 한다.

앞의 사고 사례에서는 여섯 파일이 응용을 떠나기 전에 인가 증서와 결합된 정책 상태에 따라 공개 여부를 결정한다. “Model A”는 추론 전에 서명된 모델 아티팩트 명세서와 인가된 추론 피어로 해석된다. 셀 문자열은 별도로 인가된 부수 효과 실행기 전이가 실행할 때까지 제안으로 남는다. 최종 검증 가능 실행 증거는 이러한 결정을 이후 커밋과 연결되는 증거 루트에 결합한다.

그림 2는 이 순서를 나타낸다. 도구가 제안되는지는 선택적이지만, 제안된 도구의 권한 부여는 선택 사항이 아니다.



도구가 제안되는지는 선택적이지만,
제안된 도구의 권한 부여는 선택 사항이 아니다.

그림 2: 거버넌스 적용 교환의 프로토콜 설계도. 보호 대상 작업은 정해진 순서에 따라 권한을 검증한 뒤 진행된다. 모델이 생성한 도구 제안은 실행 전에 독립적인 인가 전이를 거쳐야 한다. 본 그림은 의도한 의미론을 설명하며 구현 범위를 측정할 결과가 아니다.

6.4 서버가 주도하는 모델 결정

DARI는 사용자에게 표시되는 모델명과 보안 식별 정보를 구분하며, 다음 세 식별자를 별도로 관리한다.

Service Model → 모델 아티팩트 명세서 → 추론 피어.

인증 후 응용은 권리, 조직 정책, 배포 프로파일, 지역, 클라이언트 기능에 따라 범위가 정해진 유효 모델 카탈로그를 받는다. Model Descriptor는 멀티모달 입력, 구조화 출력, 병렬 도구, 캐시, 추론 제어, 재개 가능성과 같은 의미 기능을 광고하되 엔드포인트를 공개하지 않는다. inference-open 메시지는 안정적인 Service Model과 카탈로그 개정본을 참조한다. 거버넌스 릴레이는 오래되거나 허용되지 않은 선택을 거부하고, 서명된 모델 아티팩트 명세서를 해석한 뒤 인가된 추론 피어를 선택한다. Service Model은 사용자에게 보이는 신원, 명세서는 승인된 아티팩트 및 서빙 구성, 피어는 해당 아티팩트를 현재 실행할 수 있는 위치를 뜻한다. 호출자는 선택을 표현할 수 있지만 문자열이나 base URL을 신뢰 인프라로 바꿀 수 없다.

그림 3는 사용자에게 표시되는 모델명이 실제 라우팅 대상을 임의로 결정하지 못하도록 세 가지 식별 정보를 분리하는 방식을 보여준다.

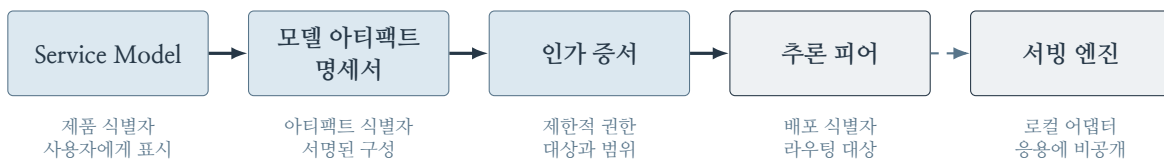


그림 3: 서버가 주도하는 모델 결정의 프로토콜 설계. 제품, 아티팩트, 배포 신원은 거버넌스 릴레이가 등록된 추론 피어를 결정할 때까지 구분된다. 서빙 엔진은 로컬 구현 요소이며 응용이 선택할 수 있는 엔드포인트가 아니다.

6.5 도구 권한과 프롬프트 인젝션

DARI는 프롬프트 인젝션으로 생성된 출력에도 모델 출력은 제안일 뿐 권한이 아니라는 규칙을 적용한다. Tool Descriptor는 실행 위치, 위험 등급, 인자 스키마, 승인 정책, 역등성, 프로비넌스 요건을 지정한다. 스트리밍 중인 인자는 완전한 형태로 수신되고 인가되기 전까지 실행할 수 없다. 저장소 텍스트, 채팅, 파일, 도구 출력은 신뢰 레이블을 유지하지만 인가 증서의 범위를 확장할 수 없다. 따라서 주입된 텍스트는 독립적으로 통제되는 권한 경계를 통과해야 한다. DARI는 제안과 실행을 허용·변환·거부한 결정을 모두 기록한다.

표 2: 권위 있는 DARI 구현 상태. “구현됨”은 구현된 동작이 아니라 필요한 프로토콜 소스와 테스트 작업을 뜻한다.

ID	주장	상태	증거
C1	결정적 프레임링과 정규 CBOR	구현됨	프레임 및 직렬화 테스트
C2	TLS/TCP 및 QUIC 바인딩	구현됨	TLS/TCP 및 QUIC 전송 테스트
C3	transcript 결합 피어 인증	구현됨	transcript 결합 인증 테스트
C4	정규 형식의 서명된 인가 범위	구현됨	인가 테스트
C5	권한 위임 범위 축소	구현됨	권한 위임 테스트
C6	결정적 최종 검증 가능 실행 증거	구현됨	검증 가능 실행 증거 테스트
C7	브라우저 바인딩	확장 프로파일	dari.web/1 벡터
C8	도메인 간 연합	확장 프로파일	dari.federation/1 벡터

7 인과 프로비넌스와 검증 가능 실행 증거

감사의 목적은 특정 권한 아래 산출물이 생성된 과정을 확인하는 데 있다. Evidence Graph는 사용자의 작업 의도, 선택한 컨텍스트, 인가 결정, 모델 호출과 출력, 도구 제안과 승인, 실행 결과, 코드 편집, 테스트, 검토, 소스 제어 산출물 사이의 인과관계를 표현한다. 각 노드는 콘텐츠 주소와 유형으로 식별되며, 간선은 원인, 파생, 공개, 변환, 결합 관계를 나타낸다. 프로토콜이 요구하는 상태 전이가 누락되면 전체 인과관계에 검증 가능한 단절이 발생한다. 거버넌스 경로 밖에서 수행된 사건은 검증 가능 실행 증거의 관측 범위 밖에 남는다.

교환 무결성을 간결하게 표현하기 위해 $r_0 = H(\text{domain} \parallel \text{exchange-open})$ 으로 두고 다음과 같이 정의한다.

$$r_i = H(\text{domain} \parallel r_{i-1} \parallel H(e_i)), \quad (3)$$

e_i 는 i 번째 증거 사건의 정규 표현이다. 서명된 검증 가능 실행 증거는 최종 루트를 교환, 관련 신원, 인가 증서와 정책 상태의 다이제스트, 모델 아티팩트 명세서, 작업 결과, 보존·반출 프로파일과 결합한다. 전체 사건을 순서대로 확보한 감사자는 루트를 다시 계산하여 종료된 교환과의 일관성을 검증할 수 있다. 임의로 선택한 일부 사건만 공개하면서 포함 여부까지 증명하려면 별도의 커미트먼트 또는 inclusion proof 구조가 필요하며, 현재의 체인 핵심 연산만으로는 이를 제공하지 않는다. 결정적 최종 검증 가능 실행 증거의 직렬화기와 검증기는 추가 구현이 필요하다.

이 구조는 명시된 구성 요소 신뢰 가정 아래 변조 여부를 검증한다. 침해된 권한 구성 요소는 거짓 원천 데이터를 낼 수 있고, 모든 서명자를 통제하는 공모 집단은 일관된 허위 기록을 만들 수 있다. 구성 요소 간 검증 가능 실행 증거와 외부 투명성은 단일 주체에 대한 신뢰를 줄이지만 원천 사건의 사실성을 확립하지는 않는다. 따라서 암호학적 무결성과 의미적 진실성은 서로 다른 속성으로 다룬다.

선택적 반출 프로파일은 민감한 노드를 커미트먼트 또는 비식별 요약으로 대체할 수 있으나, 검증 가능한 연결은 현재 체인 벤치마크가 입증한 성질이 아니라 설계 요구사항이다. 리팩터링이나 병합 이후의 소스 코드 귀속은 확률적으로 다루고, 이진 “AI 생성” 레이블 대신 신뢰도와 변환 이력을 제시해야 한다.

8 증거 상태와 참조 프로파일

DARI는 체크인된 구현 주장 행렬과 함께 개방형 명세로 공개된다. 벤치마크 스냅샷은 저장소 커밋 0234034이다. 이 구현은 아래에서 측정하는 레코드 계층과 전송 바인딩을 구현하지만, 그 자체로 더 강한 인증, 인가, 위임, 검증 가능 실행 증거 주장을 입증하지는 않는다.

8.1 권위 있는 구현 주장 행렬

8.2 평가 대상 Patty 호환 프로파일

DARI는 Patty Co., Ltd.의 이전 내부 프로토콜 구현에서 발전하였다. 평가 대상 호환 프로파일은 배포된 레코드와 메시지 의미론을 보존하며, 개방형 명세는 인가 및 검증 가능 실행 증거 인터페이스를 일반화한다.

이 참조 프로파일에서 Patty Code Harness는 응용 역할을, 기존 Relay는 거버넌스 릴레이 역할을, Patty Inference Agent(PIA)는 추론 피어 역할을 맡는다. Patty Model Package(PMP)는 중립적 모델 아티팩트 명세서의 프로파일별 선행 객체이다. 이 프로파일은 재사용 가능한 vLLM 및 SGLang 어댑터와 사용자 정의 **EngineAdapter** 경계를 포함한다. 이 명칭은 호환성과 통합 증거를 기술할 뿐 DARI 커널 객체가 아니다. C3-C6는 참조 구현에서 독립적으로 구현·검증되었으며, 프로파일 통합 여부와 무관하다.

9 평가 질문과 기준선

평가는 상호작용 성능을 유지하면서 거버넌스를 집행할 수 있는지를 다룬다. 구체적인 질문은 다음과 같다. (Q1) DARI가 연결 및 추론 전 지연에 추가하는 비용은 얼마인가? (Q2) 스트림 증가에 따라 거버넌스 릴레이 비용은 어떻게 변하는가? (Q3) 검증 가능한 인과 경로에 수반되는 증거 및 저장 비용은 얼마인가? (Q4) 프로토콜 상태가 거부하는 적대 사례는 무엇인가? (Q5) 소프트웨어 변경 이후 프로비넌스는 얼마나 정확하게 유지되는가?

9.1 기준선

목표에 맞춘 다섯 기준선을 정의한다. B0는 최소 보안 이진 스트림, B1은 bearer 인증 HTTPS/JSON 스트리밍, B2는 동등한 게이트웨이 정책 및 로깅을 더한 HTTPS/JSON, B3는 Credential 및 세션 결합과 최소 거버넌스를 적용한 DARI, B4는 인가 증서, 정책 상태 결합, 콘텐츠 검사, 인가 결정, 증거를 적용한 DARI이다. 주된 비교는 동등한 거버넌스와 다른 수명주기를 비교하는 B2 대 B4, 그리고 거버넌스의 한계 비용을 비교하는 B3 대 B4이다. MCP와 A2A는 성능 기준선이 아니라 의미론적으로 인접한 프로토콜로 다룬다.

종단 간 실험은 연결 p50/p95/p99, 첫 인가 결정까지의 시간, TTFT, 토큰 간 지연, 지속 처리량, CPU 시간, 할당량, 스트림당 메모리, 증거 바이트를 보고해야 한다. 환경에는 CPU, 메모리, NIC, RTT, 토폴로지, OS, 런타임 및 전송 라이브러리 버전, 모델/양자화, GPU, 정책 모듈, 저장 백엔드를 포함해야 한다.

9.2 보안 및 프로비넌스 실험

보안 부정 테스트에는 미등록 피어, 만료되거나 재사용된 인가 증서, 범위를 축소하지 않는 자식 증서, 알 수 없는 정책 상태 다이제스트, 오래된 카탈로그, 미승인 모델 아티팩트 명세서, 유효하지 않은 추론 피어, 피어 프로파일에 허용되지 않은 메시지, 잘못된 상태 전이 순서, 재개 후 동일 부수 효과의 중복 실행, 프롬프트 인젝션을 통한 권한 상승, 변조된 검증 가능 실행 증거가 포함된다. 프로비넌스의 정확성은 모델이 생성한 함수에 사람이 추가 편집을 수행하고, 파일명 변경, 함수 이동, rebase, merge, 다중 에이전트 수정을 적용한 뒤 측정해야 한다. 일부 사례만 제시하기보다 정밀도, 재현율, 신뢰도 보정을 함께 보고하는 것이 적절하다.

10 시스템 핵심 연산 측정

10.1 실험 환경

본 논문은 평가 대상 구현의 프레이밍, 암호, 증거 핵심 연산이 네트워크 또는 모델 처리 시간에 가려지지 않도록 각 비용을 분리해 측정하였다. Apple M4 Pro, 논리 CPU 14개, RAM 48 GiB, macOS 27.0, arm64 환경에서

표 3: 5회 실행 중앙값으로 산출한 메모리 내 시스템 핵심 연산. Record 테스트는 인코딩과 디코딩을 포함한다.

연산	시간/op	B/op	할당 횟수
Record, 1 KiB	290.2 ns	2,384	7
Record, 64 KiB	8.46 μ s	139,472	7
Record, 1 MiB	97.0 μ s	2,105,556	7
CBOR Hello 왕복	599.4 ns	592	9
증거 체인 갱신	73.05 ns	32	1
1 KiB 객체 다이제스트	403.1 ns	32	1
Ed25519 서명+검증	42.7 μ s	64	1

로컬 측정하였고, 각 벤치마크를 5회 반복하여 중앙값을 산출하였다. 이 결과는 B0–B4 시스템 비교를 위한 재현 가능한 하위 계층 기준선을 제공한다. 인가 증서 검증, 범위 축소, 브라우저 바인딩, 연합, 결정적 검증 가능 실행 증거 완결 처리는 측정하지 않았다.

연산 o 에 대해 보고하는 지연은 다음과 같다.

$$\tilde{t}_o = \text{median} \left\{ t_o^{(1)}, t_o^{(2)}, \dots, t_o^{(5)} \right\}. \quad (4)$$

아티팩트에는 $\tilde{t}_o$ 만 보존하였다. 다섯 개별 관측값은 남아 있지 않으므로 산포, 신뢰구간, 통계적 유의성을 보고하지 않는다.

1 MiB payload의 Record 인코딩·디코딩 시간은 97.0 μ s였으며, 고정 비용이 분산되면서 측정된 세 가지 크기에서 바이트당 처리 시간이 감소하였다. Record payload 크기를 s 라 할 때 바이트당 비용과 유효 payload 처리량을 다음과 같이 정의한다.

$$c(s) = \frac{\tilde{t}_{\text{record}}(s)}{s}, \quad q(s) = \frac{s}{\tilde{t}_{\text{record}}(s)}. \quad (5)$$

$c(s)$ 는 1 KiB에서 0.283 ns/byte, 1 MiB에서 0.0925 ns/byte로 감소하며, 이에 대응하는 $q(s)$ 는 3.53에서 10.81 GB/s(10.1 GiB/s)로 증가한다. 증거 체인 갱신 73.05 ns는 증거 사건마다 적용 가능한 수준이고, 서명 및 검증 42.7 μ s는 교환 또는 검증 가능 실행 증거 경계에 실용적으로 적용할 수 있는 수준이다.

개별 수치의 의미를 상호작용형 AI의 지연시간과 연결하기 위해, 거버넌스 적용 교환 수명주기에서 사용하는 네 핵심 연산, 즉 1 KiB Record 왕복, 증거 체인 갱신, 객체 다이제스트, Ed25519 서명 및 검증으로 비교 묶음을 구성하였다. 각 연산의 측정값을 산술적으로 합한 결과는 다음과 같다.

$$L_{\text{DARI,1KiB}} = 0.2902 + 0.07305 + 0.4031 + 42.688 = 43.45435 \mu\text{s}. \quad (6)$$

MLPerf Inference는 Llama 2 70B의 상호작용형 서비스에 99백분위수 TTFT 450 ms 기준을 적용한다 [10]. 이 기준에 대한 DARI 핵심 연산 묶음의 비율은

$$\rho = \frac{L_{\text{DARI,1KiB}}}{450 \text{ ms}} = 9.66 \times 10^{-5} = 0.0097\% \quad (7)$$

이다. 기준 지연시간은 합산한 핵심 연산 비용보다 10,000배 이상 크다. 이 묶음의 98.2%는 Ed25519 서명 및 검증이 차지하며, 프레이밍, 다이제스트, 증거 체인 연산은 나머지 0.77 μ s를 차지한다. 따라서 측정된 핵심 연산 비용은 비교에 사용한 상호작용형 LLM 지연시간 예산보다 네 자릿수 이상 작다.

메모리 비용을 분리하기 위해 Record 벤치마크 한 회의 할당 바이트를 $B_{op}(s)$ 라 하고 할당 증폭을 다음과 같이 정의한다.

$$A(s) = \frac{B_{op}(s)}{s}. \quad (8)$$

$A(s)$ 는 1 KiB에서 2.33, 1 MiB에서 2.01로 감소한다. 매 반복에서 인코딩 버퍼와 디코딩 Record를 모두 할당하므로 큰 payload의 할당량은 payload 크기의 약 두 배이며, 이는 구체적인 최적화 대상이다.

그림 4는 네 자릿수 범위의 차이를 로그 척도로 보이며, 표 3가 정확한 수치의 기준이다.

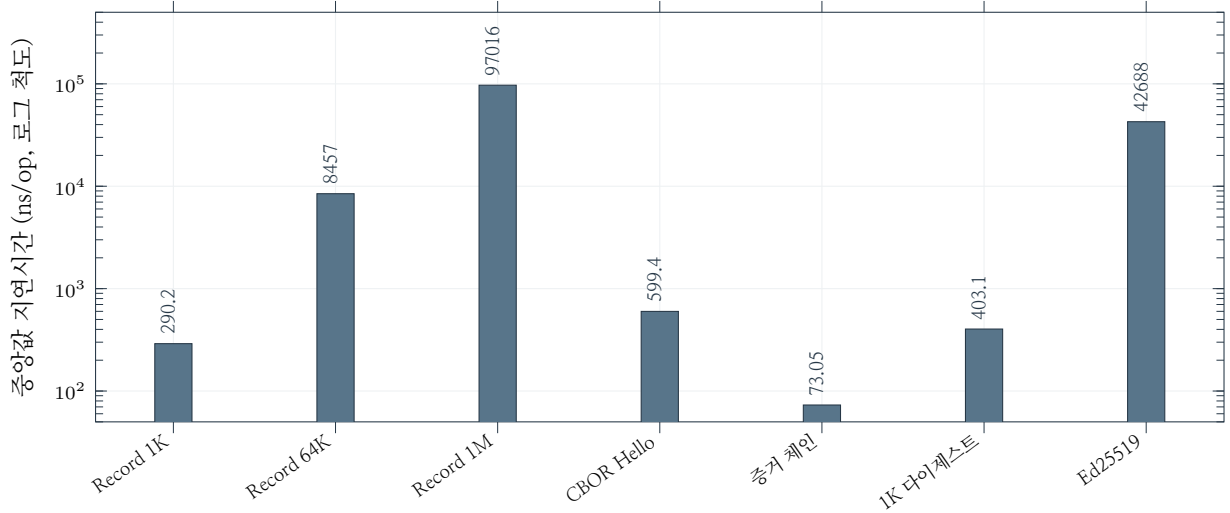


그림 4: 저장소의 TSV 데이터에서 산출한 일곱 가지 메모리 내 핵심 연산의 중량값 지연시간. 네트워크, 정책, 저장소, 모델, GPU, 토큰 생성 비용은 제외하며, 로그 척도를 사용하여 분리 측정된 CPU 비용을 식 7의 상호작용 지연 예산과 직접 비교할 수 있다.

이들 핵심 연산은 정규 증거 생성, 색인, 보존, 서명된 검증 가능 실행 증거를 구성하는 반복적인 기반 연산이다. 추가적인 메모리 할당 최적화를 적용하기 전에도 1 KiB 연산 묶음은 상호작용형 TTFT 기준의 1만분의 1 미만을 사용하므로, 정책 평가, 전송, 저장, 모델 서빙에 충분한 지연시간 여유를 남긴다.

평가 커밋에서는 전체 저장소 테스트가 통과하였다. 별도의 범위 감사 결과, 일부 적합성 테스트의 이름이 실제 검증식보다 넓은 속성을 나타내는 것으로 확인되었다. 불변조건 1-5와 7-12의 이름을 가진 테스트 11개가 있으며 6에 해당하는 테스트는 없다. 일부 통과 테스트는 이름이 나타내는 속성의 대리 지표만 검사한다. 예를 들어 기존 정책 에포크 테스트는 알 수 없는 상태의 거부가 아니라 연결 준비 상태를 확인하고, 재연결 테스트에는 검증식이 없다. 이에 따라 저장소 테스트 통과 여부와 불변조건 검증 범위를 구분하여 보고한다. 상세 분석 결과는 부록 A에 제시한다.

10.2 해석

비교 연산 묶음은 상호작용형 LLM 지연 기준의 0.0097%를 차지하고, 대용량 레코드 처리량은 10 GiB/s를 넘는다. 이 측정값은 TLS/QUIC 연결, 정책 모듈, 데이터베이스 및 캐시 접근, 콘텐츠 분류기, 네트워크 구성, 모델 스케줄링, 증거 저장에 사용할 수 있는 지연시간 예산이 충분히 남아 있음을 나타낸다. B0-B4 실험은 이러한 시스템 수준 구성 요소를 정량화하고, 구현이 필요한 부정 테스트는 거버넌스 릴레이가 DARI의 권한 모델을 실제 거부 동작으로 집행하는지를 평가해야 한다.

표 4: DARI와 인접 시스템 계열의 적용 범위를 정렬한 정성 비교.

시스템 계열	주된 경계	실시간 목적 한정 권한	인라인 모델/패키지 신원	상호작용형 코드 인과 프로비넌스
Model API	응용 - 모델 서비스	일반적으로 응용에서 정의	대개 호출자에게 보이는 모델 식별자	외부 시스템
AI gateway	응용 - 제공자 중재	게이트웨이/정책에 의존	제공자 라우트에 의존	로그/플러그인
MCP	AI 응용 - 도구/컨텍스트 제공자	배포별 권한 설정에 의존	지원 범위 밖	지원 범위 밖
A2A	에이전트 - 에이전트 작업/아티팩트 교환	프로토콜 및 작업 설정에 의존	지원 범위 밖	지원 범위 밖
in-toto/SLSA	공급망 단계/아티팩트	단계/빌드 정책	아티팩트 신원	단계/빌드 이후 프로비넌스
DARI	응용 - 거버넌스 릴레이 - 추론 피어/runtime	인가 증명 + 결합된 정책 상태	Service Model + 모델 아티팩트 명세서 + 추론 피어	거버넌스 적용 교환 그래프/검증 가능 실행 증거

11 비교 범위

표 4는 기여의 범위를 하위 메커니즘이 아니라 조합과 수명주기 의미론에 둔다. 기존 게이트웨어도 DARI의 개념 상당수를 구현할 수 있으므로, 경험적 구분점은 배포별 미들웨어와 공유 프로토콜 상태가 상호운용성, 권한 공백, 실패 동작에서 서로 다른 결과를 만드는데 있다. 제안한 B2-B4 비교는 이 차이를 측정하도록 설계하였다.

12 권한 외재화의 보안 효과

DARI는 모델을 신뢰할 수 없는 주체로 취급하고 모델 출력 채널을 통해 행사할 수 있는 권한을 제한한다. 등록되지 않은 일반 클라이언트에는 유효한 Credential과 인가 증서가 없다. 응용 키가 탈취되더라도 증서의 유효기간, 저장소와 작업 목적의 범위, 폐기 상태, 선택적 장치 증명에 따라 권한이 제한된다. 거버넌스 릴레이가 인가된 Service Model을 서명된 모델 아티팩트 명세서와 인증된 추론 피어를 통해서만 해석하면 위조된 모델명으로 엔드포인트를 선택할 수 없다. 프롬프트 인젝션으로 생성된 도구 호출은 모델 출력 채널 밖의 독립적인 인가 전이를 거쳐야 하므로 스스로 실행 권한을 획득할 수 없다. 이는 명세가 규정하는 보안 효과이며, 평가 대상 코드가 이를 집행한다고 주장하려면 C3-C6의 구현이 필요하다.

재생 공격을 막으려면 연결 transcript에 결합된 인증과 역등성 증거가 필요하다. 다른 전송 방식으로 전환하더라도 동일한 권한 객체와 상태 기계를 유지해야 한다. 증거가 변조되면 체인의 루트 해시가 달라지지만, 모든 증거 서명 주체를 장악한 공격자는 일관된 허위 기록을 만들 수 있다. 또한 평문을 처리하는 악의적 릴레이는 내용을 열람하고 사건을 누락하거나 왜곡할 수 있다. 구성 요소별 검증 가능 실행 증거, 제한된 보존 기간, 독립적인 외부 반출, 선택적 payload 보호는 이러한 신뢰 의존성을 낮추지만 완전히 제거하지는 못한다.

이러한 보안 속성은 DARI의 검증 프로파일을 요구한다. 체크인된 로컬 개발 프로파일은 설치 편의를 위해 자체 서명 인증서와 단순화된 증명 발급을 사용한다. 배포 프로파일은 조직 발급 Credential, 인증서 검증, 폐기 상태, transcript 결합 증명 검증을 요구할 수 있다. 이러한 설정만으로는 아직 구현이 필요한 피어 인증기 및 인가 테스트를 대신할 수 없다.

13 점진적 게이트웨이 전환

하나의 프로토콜 커널은 wire 의미론을 분기하지 않고 활성 모듈, 정책 기본값, 보존, 이동성, 인프라 배치를 달리하여 퍼블릭 클라우드, 엔터프라이즈, 소버린 프로파일을 지원한다. 소버린 배포는 로컬 PKI, 카탈로그, 추론 피어, 오프라인 서명 업데이트 번들을 사용할 수 있다. 브라우저 바인딩과 도메인 간 연합은 확장 프로파일이며, 벤더 간 상호운용성은 프로파일 지원만으로 추론하지 않는다.

기존 시스템에 도입할 때는 호출자 목록화, 카탈로그/제어 스키마의 추가, 기존 게이트웨이 옆의 병행 관찰, 비교 가능한 요청의 이중 기록, 응용 집단별 canary, rollback 게이트를 순차적으로 적용할 수 있다. 평가 대상 Patty 호환 프로파일은 기존 클라이언트와 메시지 경계의 보존을 보여주지만, 독립적인 벤더 간 상호운용성을 입증하지 않는다.

14 논의: 프로토콜 적용 범위와 결과 거버넌스

DARI는 에이전트 프로토콜이 메시지 전달뿐 아니라 메시지가 일으키는 결과도 표현해야 함을 시사한다. 텍스트만 반환하는 시스템에는 요청 인증과 응용 로그가 충분할 수 있다. 비공개 컨텍스트를 외부에 공개하고, 도구를 실행하며, 저장소를 변경하고, 지속되는 산출물을 만드는 시스템에서는 프로토콜 경계에서 상태 전이에 대한 권한도 다루어야 한다.

DARI는 인접 표준을 대체하지 않고 보완한다. 적용 기준은 응용이 만드는 부수 효과의 지속성과 권한 수준이다. 채팅 응용은 저장소 도구를 활성화하지 않은 채 신원, 모델 권한, 증거를 사용할 수 있고, 코딩 에이전트는 지속적 상태 변경을 위한 역량을 활성화할 수 있다.

응용 범위. 추론, 도구, 컨텍스트, 파일, 채팅, 멀티모달 입력, 지시문은 신원 및 세션 인프라를 공유하면서 역량 단위로 분리된다. 따라서 일반 채팅 응용도 파일 변경이나 도구 실행 권한을 부여받지 않고 동일한 프로토콜 코어를 사용할 수 있다.

상태와 운영. 인가 증서, 정책 상태 다이제스트, 재개, 폐기, 카탈로그, 증거는 운영 부담을 더한다. 캐시 노후화와 관리 평면 분할에는 명시적 fail-closed, bounded-stale, degrade 동작이 필요하다. 이진 프레이밍에는 일급 진단 및 캡처 도구도 필요하다.

프라이버시. 세밀한 프로비넌스 기록은 직원 감시 수단으로 변질될 수 있다. 따라서 수집 목적의 제한, 최소 수집, 역할별 접근 통제, 보존 기간 제한, 선택적 외부 반출, 사전 고지가 필요하다. 콘텐츠 해시를 사용한다고 해서 민감 정보가 익명화되는 것은 아니며, salt가 없는 해시는 원문 추측 공격에 노출될 수 있다.

배포 및 보증 프로파일. 증거 패키지는 구현된 기반, 구현이 필요한 커널 동작, 확장 프로파일을 구분한다. 측정 프로파일은 핵심 연산의 지연시간, 처리량, 메모리 할당량을 제공하고, 주장 행렬은 필요한 인증, 인가, 위임, 검증 가능 실행 증거 작업을 식별한다. 연구 행렬은 확장성, 프로비넌스 충실도, 상호운용성, 형식 분석의 증거를 심화하는 실험을 제시한다. 이 구분은 배포 의도를 완료된 구현으로 오인하지 않게 한다.

형식 분석. 상태 전이 모델과 불변조건은 형식 검증의 대상으로 삼을 수 있다. 본 논문은 형식적 보안 증명을 제공하지 않으며, 프로비넌스는 각 구성 요소에 대한 명시적 신뢰 가정 아래 기록된 인과관계를 검증한다. 기록 내용의 의미적 정확성과 실제 저작 주체는 별도의 검증 대상이다.

15 윤리와 감시 위험

프롬프트, 파일, 도구 사용, 편집, 인간 판단에 관한 증거는 사고 대응과 책임성을 향상시키지만 과도한 모니터링을 가능하게 할 수 있다. 프로토콜이 보존 및 반출 프로파일을 지원하더라도 기술적 설정만으로는 충분하지 않다. 배포자는 적절한 목적, 직원 고지, 접근 검토, 이의 제기, 정보주체 처리, 보안 조사와 성과 관리의 분리를 마련해야 한다. 공개 배포는 운영에 필요한 최소 추적을 기본값으로 삼고, 규제 배포는 정책 영역별로 더 깊은 보존의 필요성을 입증해야 한다.

그림 1은 Qwen으로 생성한 개념 이미지이며, 측정이나 사실 비교를 포함하지 않는다. 그림 2과 그림 3는 LaTeX 기반 프로토콜 설계도로, 구현 범위가 아니라 의도한 의미론을 나타낸다. 그림 4는 체크인된 벤치마크 데이터셋에서 생성한 데이터 기반 실증 시각화이다. 보존된 중앙값은 벤치마크 하네스로 재현할 수 있으며, 새로운 통계적 주장을 위해서는 개별 실행 원자료를 별도로 공개해야 한다.

16 재현 가능성

arXiv 소스 패키지는 정확한 LaTeX 소스, 참고문헌, 개념 그림, 벤치마크 데이터셋, 구현 주장 행렬, 빌드 지침을 포함한다. 구현 저장소에는 평가 대상 프레이밍·전송 기반, 벤치마크 하네스, 앞에서 설명한 Patty 호환 프로파일도 포함된다. 구현 저장소 루트에서 다음 명령으로 보고된 핵심 연산 측정을 재현할 수 있다.

```
go test ./... -run '^$' \
  -bench 'Benchmark(RecordRoundTrip|CanonicalCBOR|'\
'EvidenceChainNext|ObjectDigest|Ed25519SignVerify)$' \
  -benchmem -count=5
```

전체 정규식은 아티팩트 README에 제시한다. PDF는 `latexmk`와 BibTeX로 오프라인 빌드할 수 있다. 개별 실행 원자료, 네트워크/부하 생성기, 토폴로지 자동화, 부정 보안 fixture, 프로비던스 데이터셋, 독립 구현 결과는 각각 더 강한 통계, 확장성, 공격 저항성, 충실도, 상호운용성 주장을 제시할 때 요구된다.

17 결론

AI가 생성한 커밋의 책임성을 평가하려면 토큰을 생성한 모델의 식별만으로는 충분하지 않다. 사용자의 지시에서 실제 시스템 변경에 이르는 과정이 컨텍스트 공개, 모델 결정, 도구 승인, 산출물 생성 전반에 걸쳐 제한된 권한 안에서 수행되었음을 확인할 수 있어야 한다.

DARI는 이 과정을 거버넌스 적용 교환으로 표현한다. Credential, 목적, 제한된 인가 증서, 정책 상태, 모델 아티팩트 명세서, 인가 결정, 인과 증거를 결합한다. 모델 출력은 제안으로 유지되고, 독립적인 프로토콜 상태 전이가 보호 대상 부수 효과를 인가한다. 검증 가능 실행 증거는 이 경로의 명세상 검증 가능한 출력이다.

평가 대상 구현은 결정적 프레이밍, 정규 CBOR, TLS/TCP 및 QUIC 바인딩을 구현한다. transcript 결합 인증, 정규 형식의 서명 범위, 위임 범위 축소, 결정적 최종 검증 가능 실행 증거는 구현이 필요하며, 브라우저와 연합 바인딩은 확장 프로파일이다. 측정된 핵심 연산 묶음은 비교에 사용한 상호작용형 TTFT 예산의 0.0097%를 차지하며, 1 MiB 레코드 처리량은 10.81 GB/s였다. 이 수치는 구현되지 않았거나 확장 프로파일에 속하는 주장에 대한 증거가 아니라 핵심 연산 측정값이다.

명세, 구현된 기반, 호환성 계보, 측정된 핵심 연산 비용은 각각 증거가 뒷받침하는 범위를 분명히 한다. 이들은 거버넌스를 응용, 인가 권한 주체, 모델 인프라, 도구, 인과 증거를 연결하는 공유 프로토콜 속성으로 발전시키는 경로를 제시한다. 구현 주장 행렬은 남은 작업을 명시한다.

참고문헌

- [1] A2A Project. Agent2agent protocol specification, 2026. <https://a2a-protocol.org/latest/specification/>.
- [2] R. Barnes, K. Bhargavan, and C. A. Wood. Hybrid public key encryption. Technical Report RFC 9180, IETF, Feb. 2022. <https://www.rfc-editor.org/info/rfc9180>.
- [3] A. Birgisson, J. G. Politz, Ú. Erlingsson, A. Taly, M. Vrabie, and M. Lentzner. Macaroons: Cookies with contextual caveats for decentralized authorization in the cloud. In *Network and Distributed System Security Symposium*, 2014.
- [4] H. Birkholz, A. Delignat-Lavaud, C. Fournet, Y. Deshpande, and S. Lasker. An architecture for trustworthy and transparent digital supply chains. Technical Report RFC 9943, IETF, June 2026. <https://www.rfc-editor.org/info/rfc9943>.
- [5] C. Bormann and P. Hoffman. Concise binary object representation (CBOR). Technical Report RFC 8949, IETF, Dec. 2020. <https://www.rfc-editor.org/info/rfc8949>.
- [6] E. Debenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, and F. Tramèr. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for llm agents. *arXiv preprint arXiv:2406.13352*, 2024. <https://arxiv.org/abs/2406.13352>.
- [7] L. Fan, Z. Li, Y. Tian, Y. Wang, R. Li, and X. Wang. The granularity mismatch in agent security: Argument-level provenance solves enforcement and isolates the llm reasoning bottleneck. *arXiv preprint arXiv:2605.11039*, 2026. <https://arxiv.org/abs/2605.11039>.
- [8] in-toto Project. in-toto specification v1.0, 2023. <https://in-toto.io/docs/specs/>.
- [9] J. Iyengar and M. Thomson. QUIC: A UDP-based multiplexed and secure transport. Technical Report RFC 9000, IETF, May 2021. <https://www.rfc-editor.org/info/rfc9000>.
- [10] MLCommons. MLPerf Inference v5.0 advances language model capabilities for GenAI, Apr. 2025. <https://mlcommons.org/2025/04/llm-inference-v5/>.
- [11] Model Context Protocol Project. Model context protocol specification, 2025-06-18 revision, 2025. <https://modelcontextprotocol.io/specification/2025-06-18>.
- [12] E. Rescorla. Channel bindings for TLS 1.3. Technical Report RFC 9266, IETF, July 2022. <https://www.rfc-editor.org/info/rfc9266>.
- [13] E. Rescorla. The transport layer security (tls) protocol version 1.3. Technical Report RFC 9846, IETF, July 2026. <https://www.rfc-editor.org/info/rfc9846>.
- [14] J. Schaad. CBOR object signing and encryption (COSE): Structures and process. Technical Report RFC 9052, IETF, Aug. 2022. <https://www.rfc-editor.org/info/rfc9052>.
- [15] SLSA Project. SLSA specification v1.2, 2026. <https://slsa.dev/spec/v1.2/>.
- [16] SPIFFE Project. Secure production identity framework for everyone standard, 2026. <https://spiffe.io/docs/latest/spiffe-specs/spiffe/>.
- [17] O. Steele, H. Birkholz, A. Delignat-Lavaud, and C. Fournet. CBOR object signing and encryption (COSE) receipts. Technical Report RFC 9942, IETF, June 2026. <https://www.rfc-editor.org/info/rfc9942>.
- [18] S. Torres-Arias, H. Afzali, T. K. Kuppusamy, R. Curtmola, and J. Cappel. in-toto: Providing farm-to-table guarantees for bits and bytes. In *28th USENIX Security Symposium*, pages 1393--1410, 2019.

- [19] C. L. Wang, T. Singhal, A. Kelkar, and J. Tuo. MI9: An integrated runtime governance framework for agentic ai. *arXiv preprint arXiv:2508.03858*, 2025. <https://arxiv.org/abs/2508.03858>.

A 연구 불변조건 보증 행렬

표 5는 평가 대상 커밋의 적합성 테스트가 각 연구 불변조건을 어느 범위까지 검증하는지 분석한 결과이다. “약함”은 테스트 이름이 나타내는 전체 조건 중 일부만 검증식으로 확인한 경우를, “부분”은 의미 있는 핵심 연산 또는 상태를 검사했지만 중단 간 경로 전체를 검증하지 않은 경우를 뜻한다.

표 5: 후보 연구 불변조건 검증 범위 분석.

ID	후보 불변조건	범위	검사 결과
I1	피어 인증 전에는 보호 대상 작업을 수행할 수 없음	부분	연결 상태 차단은 검증하지만 수신부의 증명 검증은 전체 경로를 확인하지 않음
I2	유효한 인가 증서 범위 밖의 작업을 수행할 수 없음	약함	작업 인가가 아니라 Credential의 시간 유효성만 검사
I3	알 수 없는 정책 상태 다이제스트로 작업을 수행할 수 없음	약함	정책 상태 조회 및 거부가 아니라 연결 준비 상태만 검사
I4	미승인 명세서 또는 추론 피어로 호출할 수 없음	부분	서명 변조는 검사하지만 전체 라우팅 경로와의 연결은 검증하지 않음
I5	도구 제안만으로 실행 권한을 얻을 수 없음	약함	유효한 피어 자격 증명만 검사
I6	컨텍스트 공개에는 명시적 권한이 필요함	없음	해당 조건을 직접 검증하는 적합성 테스트가 없음
I7	대체 전송 경로에서도 동일한 권한 규칙이 유지됨	약함	ALPN 상수만 검사하고 대체 전송을 통한 교환은 검증하지 않음
I8	재연결 시 완료된 작업을 중복 실행하지 않음	검증 없음	테스트 이름은 존재하지만 검증식이 없음
I9	보호 대상 교환은 검증 가능 실행 증거를 남기고 종료됨	부분	결정적 체인은 검사하지만 종료 및 증거 발급 경로는 검증하지 않음
I10	프로비넌스 데이터 변경 시 다이제스트가 달라짐	핵심 연산 구현	서로 다른 콘텐츠가 domain-separated digest를 다르게 생성
I11	피어 프로파일에 허용되지 않은 특권 메시지를 보낼 수 없음	검증 없음	메시지 목록은 생성하지만 실제 집행 경로에 입력하지 않음
I12	관리 통신과 집행 통신은 구별됨	구조 검증	서로 다른 메시지 유형 코드를 사용하는지 검사

A.1 더 강한 주장에 필요한 증거

다음 실험은 시스템 수준 성능, 보안, 프로비넌스, 상호운용성 주장에 대응하는 검증 자료를 확장한다.

- 전송 및 인증:** 인증서와 COSE 증명의 전체 검증, 폐기, transcript 결합, 재개, QUIC – TCP fallback을 시험하고 연결 p50/p95/p99를 측정한다.
- 중단 간 추론:** 동일한 payload 및 모델 출력으로 B0 – B4를 비교하고 인가 결정 지연, TTFT, 스트리밍 처리량, CPU, 할당, 메모리를 보고한다.
- 거버넌스 부정 사례:** 실제 거버넌스 릴레이 경로에서 만료되거나 재사용된 인가 증서, 범위를 축소하지 않는 자식 증서, 알 수 없는 정책 상태, 오래된 카탈로그, 미승인 명세서, 유효하지 않은 추론 피어, 프로파일이 혼동된 메시지, 완료 작업의 중복 실행을 거부하는지 검증한다.
- 확장성과 장애:** 동시 세션 및 스트림 수 증가, 거버넌스 릴레이 재시작, 관리 권한 주체 연결 중단, bounded-stale 캐시, 용량 권한 손실, 증거 저장소 성능 저하의 영향을 측정한다.
- 프로비넌스 충실도:** 인간 편집, 파일/함수 이동, rebase, merge, 다중 에이전트 변경을 포함한 레이블 데이터 셋을 공개하고 정밀도, 재현율, 신뢰도 보정을 제시한다.
- 독립 증거:** 동일한 구현 스택을 공유하지 않는 구현을 시연하고 golden vector 및 fuzz 결과를 공개하며 운영 보안 프로파일에 대한 외부 검토를 수행한다.